# คู่มือการพัฒนาระบบซอฟต์แวร์ยุค AI Era
# สำหรับหน่วยงานภาครัฐ

*Government Software Development Handbook*

*for the AI Era*

แนวปฏิบัติเชิงลึก — มาตรฐาน OWASP · ความปลอดภัยไซเบอร์ · AI Security

อธิปไตยข้อมูล · DevSecOps · MLSecOps · Zero Trust 2.0

ฉบับปี พ.ศ. 2569 (2026)

จัดทำตามมาตรฐาน OWASP Top 10 — 2025 Edition

# สารบัญ

*** กรุณากด Ctrl+A แล้ว F9 เพื่ออัปเดตสารบัญหลังเปิดไฟล์ใน Microsoft Word ***

# บทนำ — ทำไมหน่วยงานภาครัฐต้องเปลี่ยนผ่านสู่ยุค AI Era

ในยุคที่ปัญญาประดิษฐ์ (AI) กลายเป็นเครื่องมือหลักทั้งในฝั่งผู้พัฒนาและผู้โจมตี หน่วยงานภาครัฐจำเป็นต้องยกระดับกระบวนการพัฒนา ทดสอบ ติดตั้ง และดูแลระบบซอฟต์แวร์ทั้งหมดให้สอดคล้องกับภัยคุกคามที่เปลี่ยนแปลงอย่างรวดเร็ว คู่มือฉบับนี้รวบรวมและเรียบเรียงเนื้อหาจากแหล่งอ้างอิงระดับสากล ได้แก่ OWASP Top 10 — 2025, OWASP ASVS v5.0, OWASP Top 10 for LLM Applications 2025, NIST Post-Quantum Cryptography Standards, Cloud Security Alliance (CSA) Zero Trust Framework รวมถึงยุทธศาสตร์การสร้างอธิปไตยข้อมูลภาครัฐด้วยระบบเอกสารดิจิทัลอัจฉริยะ

คู่มือนี้ถูกออกแบบให้เป็น "Practical Guide" — เน้นแนวปฏิบัติที่นำไปใช้ได้จริง พร้อม Use Cases, Checklists, Architecture Diagrams และ Solution Playbooks ที่เจาะลึกเพียงพอสำหรับทีมพัฒนา ทีมรักษาความปลอดภัย และผู้บริหารเทคโนโลยีสารสนเทศของหน่วยงานภาครัฐ

**ขอบเขตของคู่มือ:**

- มาตรฐานและกรอบการทำงานด้านความปลอดภัยสากล (OWASP, NIST, CSA, ISO)
- OWASP Top 10 — 2025: โซลูชันเจาะลึกทุกข้อพร้อมตัวอย่างโค้ดและ Use Cases
- การตรวจสอบ ติดตาม และรายงานผลด้วย SIEM/SOAR/XDR
- ภัยคุกคามอุบัติใหม่: Agentic AI Attacks, Post-Quantum Cryptography, Zero Trust 2.0
- ความปลอดภัย LLM (OWASP Top 10 for LLM 2025) และ MLSecOps Pipeline
- อธิปไตยข้อมูลภาครัฐ: ระบบเอกสารดิจิทัลอัจฉริยะ Collabora Online / ONLYOFFICE
- Privacy-Preserving AI: Federated Learning, Homomorphic Encryption, TEE

# ส่วนที่ 1: มาตรฐานและกรอบการทำงานด้านความปลอดภัยสากล

## 1.1 ภาพรวม OWASP (Open Web Application Security Project)

OWASP เป็นโครงการไม่แสวงหาผลกำไรระดับสากลที่มุ่งพัฒนาความปลอดภัยของซอฟต์แวร์ โดยจัดทำเครื่องมือ มาตรฐาน และแนวปฏิบัติที่ครอบคลุมวงจรชีวิตการพัฒนาซอฟต์แวร์ทั้งหมด ตั้งแต่ขั้นตอนการออกแบบ พัฒนา ทดสอบ จนถึงการดูแลรักษา

### โครงการสำคัญของ OWASP ที่เกี่ยวข้องกับภาครัฐ

| โครงการ | วัตถุประสงค์ | การนำไปใช้ในภาครัฐ |
|---|---|---|
| OWASP Top 10 (Web) | ระบุช่องโหว่เว็บแอปพลิเคชัน 10 อันดับแรก | เกณฑ์ขั้นต่ำสำหรับ Pentest ก่อน Go-live |
| OWASP ASVS v5.0 | มาตรฐานตรวจสอบความปลอดภัย (350 ข้อ, 17 หมวด) | กำหนด Security Requirements ใน TOR/RFP |
| OWASP Top 10 for LLM 2025 | ช่องโหว่เฉพาะ Large Language Models | Guardrails สำหรับ AI Chatbot ภาครัฐ |
| OWASP SAMM | วัดระดับวุฒิภาวะด้าน Software Security | Roadmap การยกระดับ DevSecOps |
| OWASP Testing Guide | คู่มือทดสอบความปลอดภัยเว็บแอปพลิเคชัน | กรอบการทำ Pentest สำหรับผู้ตรวจสอบ |

### เปรียบเทียบ ASVS v4.0.3 กับ ASVS v5.0

| เปรียบเทียบ | ASVS v4.0.3 | ASVS v5.0 |
|---|---|---|
| จำนวนข้อกำหนด | 286 ข้อ | 350 ข้อ |
| จำนวนหมวดหมู่ | 14 บท | 17 บท (ปรับโครงสร้างใหม่) |
| Level 1 | 131 ข้อ (เกณฑ์ขั้นต่ำสูงเกินไป) | เบาลงเพื่อลด Barrier to Entry |
| Black-box Testing | คลุมเครือว่า L1 ใช้ได้หรือไม่ | ระบุชัดว่า Black-box ไม่เพียงพอทุก Level |
| Requirement Style | Technical Prescriptions | Goal-Oriented เน้น Security Outcomes |

## 1.2 มาตรฐานเสริมที่เกี่ยวข้อง

### NIST Cybersecurity Framework (CSF) 2.0

กรอบการจัดการความเสี่ยงไซเบอร์แบบครบวงจร ประกอบด้วย 6 ฟังก์ชันหลัก: Govern, Identify, Protect, Detect, Respond, Recover — เหมาะสำหรับใช้เป็น Baseline ของนโยบายความปลอดภัยระดับองค์กร

### ISO/IEC 27001:2022

มาตรฐานระบบบริหารจัดการความมั่นคงปลอดภัยสารสนเทศ (ISMS) ที่เป็นที่ยอมรับระดับสากล หน่วยงานภาครัฐควรพิจารณาขอรับรองมาตรฐานนี้สำหรับระบบสำคัญ

### CSA STAR (Cloud Security Alliance)

กรอบการประเมินความปลอดภัยคลาวด์ที่ใช้ Cloud Controls Matrix (CCM) และ Consensus Assessment Initiative Questionnaire (CAIQ) เหมาะสำหรับประเมินผู้ให้บริการคลาวด์ก่อนการจัดซื้อ

## 1.3 กำหนดการทดสอบความปลอดภัย (Pentest Schedule)

| เหตุการณ์ | ประเภทการทดสอบ | ความถี่ |
|---|---|---|
| ก่อนเปิดใช้ระบบจริง (Pre-launch) | Full Pentest (Grey/White Box) | ครั้งเดียวก่อน Go-live |
| เปลี่ยนแปลงฟีเจอร์หลัก | Targeted Pentest + Regression | ทุกครั้งที่มี Major Release |
| ระบบปกติ | VA Scan อัตโนมัติ | รายสัปดาห์/รายเดือน |
| การประเมินรายปี | Full Pentest + Compliance Check | อย่างน้อยปีละ 1 ครั้ง |

## 1.4 Disaster Recovery & Business Continuity

| ระดับบริการ | RTO เป้าหมาย | RPO เป้าหมาย | กลยุทธ์กู้คืน |
|---|---|---|---|
| Mission-Critical (ระบบชำระเงิน) | < 1 ชั่วโมง | < 15 นาที | Active-Active, Real-time Replication |
| Business-Critical (เว็บไซต์หลัก) | < 4 ชั่วโมง | < 1 ชั่วโมง | Warm Standby, Hourly Backup |
| Standard (ระบบสนับสนุน) | < 24 ชั่วโมง | < 4 ชั่วโมง | Cold Standby, Daily Backup |
| Low Priority (ระบบทดสอบ) | < 72 ชั่วโมง | < 24 ชั่วโมง | Backup & Restore from Archive |

# ส่วนที่ 2: โซลูชันเจาะลึก OWASP Top 10 — 2025

OWASP Top 10 ปี 2025 ได้รับการปรับปรุงเพื่อสะท้อนภัยคุกคามยุค AI โดยเฉพาะ ส่วนนี้จะเจาะลึกแต่ละข้อพร้อม Use Cases และโซลูชันที่ปฏิบัติได้จริงสำหรับหน่วยงานภาครัฐ

## 2.1 A01:2025 — Broken Access Control

ช่องโหว่ด้านการควบคุมการเข้าถึงยังคงเป็นอันดับ 1 ต่อเนื่อง ครอบคลุมทั้ง IDOR, Path Traversal, Missing Function Level Access Control และ CORS Misconfiguration

### Use Case: ระบบสวัสดิการภาครัฐ

*สถานการณ์: ระบบจ่ายสวัสดิการออนไลน์ที่เจ้าหน้าที่สามารถดูข้อมูลผู้รับสวัสดิการ โดยเปลี่ยน ID ใน URL (/api/beneficiary/12345) เพื่อเข้าถึงข้อมูลของผู้อื่น (IDOR)*

**โซลูชัน:**

1. ใช้ Attribute-Based Access Control (ABAC): ตรวจสอบว่าผู้ใช้มีสิทธิ์เข้าถึงข้อมูลเฉพาะรายการที่ตนเองรับผิดชอบ
2. เปลี่ยนจากการใช้ Sequential ID เป็น UUID v4 เพื่อป้องกัน Enumeration
3. ใช้ Server-Side Authorization Check ทุก Endpoint — ห้ามพึ่ง Client-Side เพียงอย่างเดียว
4. บันทึก Access Log ทุกครั้งที่มีการเข้าถึงข้อมูลส่วนบุคคล เพื่อ Audit Trail ตาม PDPA

**ตัวอย่าง Server-Side Check (Pseudocode):**

```
# Python Flask Example - ABAC Check
@app.route('/api/beneficiary/<uuid:bid>', methods=['GET'])
@login_required
def get_beneficiary(bid):
    user = get_current_user()
    beneficiary = Beneficiary.query.get_or_404(bid)

    # ABAC Check: ผู้ใช้ต้องอยู่ในเขตรับผิดชอบเดียวกัน
    if not user.has_permission('read', beneficiary):
        abort(403)  # Forbidden
        audit_log(user, 'UNAUTHORIZED_ACCESS', bid)

    audit_log(user, 'READ', bid)
    return jsonify(beneficiary.to_safe_dict())
```

## 2.2 A02:2025 — Cryptographic Failures

ครอบคลุมการใช้ Algorithm ที่ล้าสมัย (MD5, SHA-1, DES), การจัดเก็บ Key ไม่ปลอดภัย, Missing Encryption at Rest/Transit และ Certificate Mismanagement

### Use Case: ระบบทะเบียนราษฎร์

*สถานการณ์: ฐานข้อมูลทะเบียนราษฎร์ใช้ MD5 hash สำหรับเลขบัตรประชาชน และส่งข้อมูลระหว่าง Microservices ผ่าน HTTP ภายใน Internal Network โดยไม่เข้ารหัส*

**โซลูชัน:**

5. เปลี่ยนจาก MD5 เป็น Argon2id สำหรับ Password Hashing และ AES-256-GCM สำหรับ Data Encryption at Rest
6. บังคับ mTLS (Mutual TLS) สำหรับ Service-to-Service Communication แม้ใน Internal Network
7. ใช้ Hardware Security Module (HSM) หรือ Cloud KMS สำหรับ Key Management — ห้ามเก็บ Key ใน Source Code
8. ตั้ง Automated Certificate Rotation ด้วย cert-manager (Kubernetes) หรือ Vault PKI
9. เตรียม Migration สู่ Post-Quantum Cryptography (PQC) สำหรับข้อมูลที่มีอายุยาว

## 2.3 A03:2025 — Injection

ครอบคลุม SQL Injection, XSS, Command Injection, LDAP Injection, NoSQL Injection และ Prompt Injection (สำหรับ LLM)

### Use Case: ระบบ e-Service ภาครัฐ

*สถานการณ์: ระบบค้นหาข้อมูลบริการภาครัฐที่รับ Input จากผู้ใช้โดยตรงไปต่อ SQL Query โดยไม่มี Parameterization*

**โซลูชัน:**

10. ใช้ Parameterized Queries / Prepared Statements เท่านั้น — ห้ามต่อ String
11. ใช้ ORM (Object-Relational Mapping) เช่น SQLAlchemy, Hibernate, Prisma
12. ติดตั้ง WAF (Web Application Firewall) พร้อม OWASP Core Rule Set
13. ใช้ Content Security Policy (CSP) Header เพื่อป้องกัน XSS
14. ทำ Input Validation ทั้ง Allowlist (Whitelist) Approach

```
# ตัวอย่าง Parameterized Query (Python + SQLAlchemy)
# WRONG (อันตราย): SQL Injection
query = f"SELECT * FROM citizens WHERE id = '{user_input}'"

# CORRECT (ปลอดภัย): Parameterized Query
result = db.session.execute(
    text("SELECT * FROM citizens WHERE id = :citizen_id"),
    {"citizen_id": user_input}
)
```

## 2.4 A04:2025 — Insecure Design

ช่องโหว่จากการออกแบบที่ไม่ปลอดภัยตั้งแต่ต้น ไม่สามารถแก้ได้ด้วยการเขียนโค้ดที่สมบูรณ์แบบ

**โซลูชันสำหรับภาครัฐ:**

- ทำ Threat Modeling (STRIDE/PASTA) ทุกโครงการก่อนเริ่มพัฒนา
- กำหนด Security Requirements ใน TOR/RFP ตามข้อกำหนด ASVS v5.0
- ใช้ Secure Design Patterns: Defense in Depth, Least Privilege, Fail-Safe Defaults
- จัดทำ Abuse Case Testing ควบคู่กับ Use Case Testing

## 2.5 A05:2025 — Security Misconfiguration

**โซลูชันสำหรับภาครัฐ:**

- ใช้ Infrastructure as Code (IaC) เช่น Terraform, Ansible พร้อม Security Linting
- สแกน Configuration ด้วย CIS Benchmarks อัตโนมัติ
- ปิด Default Credentials, Debug Endpoints, Directory Listing
- ใช้ Hardened Container Images (Distroless/Alpine)
- ตั้ง Security Headers: HSTS, X-Content-Type-Options, X-Frame-Options, CSP

## 2.6 A06:2025 — Vulnerable and Outdated Components

**โซลูชันสำหรับภาครัฐ:**

- ใช้ Software Composition Analysis (SCA) เช่น Snyk, OWASP Dependency-Check ใน CI/CD
- จัดทำ Software Bill of Materials (SBOM) ตามรูปแบบ CycloneDX หรือ SPDX
- ตั้ง Automated Dependency Update ด้วย Dependabot หรือ Renovate
- กำหนด SLA: Critical < 48 ชม., High < 7 วัน, Medium < 30 วัน

## 2.7 A07:2025 — Identification and Authentication Failures

**โซลูชันสำหรับภาครัฐ:**

- บังคับ Multi-Factor Authentication (MFA) สำหรับระบบทุกระดับ
- ใช้ Passwordless Authentication เมื่อเป็นไปได้ (FIDO2/WebAuthn)
- กำหนด Password Policy ตาม NIST SP 800-63B: ความยาวขั้นต่ำ 8 ตัวอักษร, ตรวจ Breached Password List
- ใช้ Rate Limiting และ Account Lockout Policy ที่เหมาะสม

## 2.8 A08:2025 — Software and Data Integrity Failures

**โซลูชันสำหรับภาครัฐ:**

- ใช้ Code Signing สำหรับทุก Release Artifact
- ตรวจสอบ Integrity ของ CI/CD Pipeline ด้วย SLSA Framework
- ใช้ Subresource Integrity (SRI) สำหรับ Third-party Libraries
- ตั้ง Container Image Signing ด้วย Sigstore/Cosign

## 2.9 A09:2025 — Security Logging and Monitoring Failures

**โซลูชันสำหรับภาครัฐ:**

- ติดตั้ง Centralized Logging ด้วย SIEM (Elastic, Splunk, Wazuh)

- บันทึก Event สำคัญ: Authentication, Authorization Failures, Data Access, Admin Actions
- ตั้ง Real-time Alerting สำหรับ Anomalies พร้อม Escalation Rules
- เก็บ Log อย่างน้อย 90 วัน (ตาม พ.ร.บ.คอมพิวเตอร์) และ Immutable Storage

## 2.10 A10:2025 — Server-Side Request Forgery (SSRF)

**โซลูชันสำหรับภาครัฐ:**

- ใช้ Allowlist สำหรับ Outbound Requests — ห้าม Wildcard
- บล็อก Internal IP Ranges (169.254.x.x, 10.x.x.x, 172.16-31.x.x, 192.168.x.x)
- ใช้ Network Segmentation แยก Application Tier จาก Internal Services
- ปิด Unnecessary URL Schemes (file://, gopher://, dict://)

# ส่วนที่ 3: การตรวจสอบ การติดตาม และการรายงานผล

## 3.1 สถาปัตยกรรม SIEM + SOAR + XDR

การรับมือภัยคุกคามสมัยใหม่ต้องอาศัยแนวทางบูรณาการ SIEM, SOAR และ EDR/XDR เข้าเป็นแพลตฟอร์มเดียว โดยใช้ AI/ML เป็นแกนกลาง:

- SIEM (Security Information & Event Management): รวบรวมและวิเคราะห์ Security Events จากหลายแหล่ง
- SOAR (Security Orchestration, Automation & Response): Automate Response ผ่าน Predefined Playbooks
- XDR (Extended Detection & Response): ตรวจจับภัยคุกคามข้าม Endpoint, Network, Cloud

### Use Case: เลือกสถาปัตยกรรมตามขนาดองค์กร

| แนวทาง | เหมาะกับ | ข้อดี |
|---|---|---|
| SIEM + XDR | องค์กรที่ต้องการ Broad Log Collection + Advanced Detection | ครอบคลุม Visibility + Deep Endpoint Analysis |
| XDR + Lightweight SOAR | องค์กรขนาดกลาง Simple Automation | Setup ง่าย ไม่ต้อง Maintain Complex Playbooks |
| Full Trifecta (SIEM+SOAR+XDR) | องค์กรขนาดใหญ่, SOC Team เต็มรูปแบบ | Maximum Coverage + Automation + Orchestration |

### ตัวเลือกเครื่องมือ: Open-Source กับ Commercial

| องค์ประกอบ | Open-Source | Commercial | Hybrid |
|---|---|---|---|
| SIEM | Elastic SIEM, Wazuh | Splunk, QRadar | Elastic SIEM + Commercial Threat Intel |
| SOAR | TheHive, Shuffle | Palo Alto XSOAR | Open-source + Commercial Playbooks |
| EDR | Velociraptor, OSSEC | CrowdStrike, SentinelOne | Open-source + Commercial AI Engine |
| Threat Intel | MISP, OpenCTI | Recorded Future | Community + Premium Intelligence |

## 3.2 KPI สำหรับ Security Operations

| KPI | คำนิยาม | Benchmark | วิธีปรับปรุง |
|---|---|---|---|
| MTTD | เวลาเฉลี่ยจากเกิดภัยคุกคามถึงตรวจพบ | ลดลงอย่างต่อเนื่อง | ML-based Anomaly Detection |
| MTTR | เวลาเฉลี่ยจากตรวจพบถึงแก้ไข | SEV-1 < 1 ชม., SEV-2 < 4 ชม. | SOAR Automation + SOPs |
| MTTA | เวลาจากแจ้งเตือนถึงเริ่มดำเนินการ | ลดลงอย่างต่อเนื่อง | Auto-assign + Escalation |
| SLA Compliance | เหตุการณ์ที่แก้ไขภายใน SLA | ขั้นต่ำ 95%, เยี่ยม 99%+ | Automated Escalation |
| VA SLA Tracking | Vulnerabilities ที่แก้ไขตามกำหนด | Critical < 48 ชม., High < 7 วัน | Risk-based Prioritization |

## 3.3 Cloud Compliance Audit Roadmap

| ขั้นตอน | กิจกรรม | เครื่องมือ |
|---|---|---|
| 1. Define Baseline | Risk-based Compliance Matrix: CIS Level 2, NIST 800-53 | CIS Benchmarks, CSA CCM |
| 2. Automate | ฝัง Policy-as-Code ใน CI/CD Pipeline | OPA, Terraform, Checkov |
| 3. Monitor | Deploy Dashboard + AI Anomaly Detection | AWS Security Hub, Azure Defender |
| 4. CSA STAR | Self-Assessment ตาม CAIQ + CCM | CSA STAR Registry |
| 5. CIS Scan | สแกนตาม CIS Foundations Benchmarks v2.0 | Prowler, ScoutSuite |
| 6. Remediate | บันทึก Findings, จัดลำดับ Fixes ตาม Severity | Jira, ServiceNow |

## 3.4 เครื่องมือตรวจสอบ Accessibility (WCAG)

| เครื่องมือ | จุดเด่น | WCAG Support | ประเภท |
|---|---|---|---|
| WAVE | Browser Extension ฟรี, Visual Overlay | WCAG 2.1/2.2 | Browser Extension + API |
| Google Lighthouse | ฝังใน Chrome DevTools | WCAG 2.1 | Built-in Browser |
| Pa11y | CI/CD Integration, Command-line | WCAG 2.1 | CLI + Node.js |
| Axe-core | Cypress/Playwright Support | WCAG 2.1/2.2 | JavaScript Library |

# ส่วนที่ 4: ภัยคุกคามอุบัติใหม่และการรับมือ (Emerging Threats & AI)

## 4.1 Agentic AI & Automated Attacks

**สถานการณ์ภัยคุกคาม:**

ระหว่างปลายปี 2025 ถึงต้นปี 2026 ผู้โจมตีได้เร่งนำ Agentic AI Framework มาใช้ในการโจมตีแบบอัตโนมัติ โดยสามารถจัดการ Attack Chain ทั้งหมดได้ตั้งแต่ Reconnaissance, Phishing, Credential Testing ไปจนถึงการหมุนเวียน Infrastructure โดยไม่ต้องมีมนุษย์ควบคุม จากผลสำรวจ 48% ของผู้เชี่ยวชาญด้านความปลอดภัยระบุว่า Agentic AI เป็นเวกเตอร์โจมตีอันดับหนึ่งในปี 2026 ขณะที่ Flashpoint ระบุว่าการกล่าวถึง AI ในแหล่งผิดกฎหมายเพิ่มขึ้น 1,500% ภายในเดือนเดียว

**กรณีศึกษา:**

- Anthropic เปิดเผยการโจมตีแบบ AI-orchestrated Cyber Espionage ครั้งแรก โดยกลุ่ม GTG-1002 — AI ดำเนินการโจมตี 80-90% โดยอัตโนมัติ
- Google GTIG ค้นพบ Adaptive Malware ที่ใช้ LLM เปลี่ยนกลยุทธ์แบบ Real-time

### Playbook: การป้องกัน Agentic AI Attacks (3 Layers)

**Layer 1 — Architecture:**

- ติดตั้ง Human-in-the-Loop (HITL) Checkpoints สำหรับการกระทำที่มีผลกระทบสูง
- ใช้ Identity Management สำหรับ Non-Human Identities (NHI) แยกจาก Human Identity
- สร้าง Immutable Audit Trails ป้องกัน Memory Poisoning

**Layer 2 — Development:**

- จัดทำ Supply Chain Scanning ก่อน Deploy ทุกครั้ง
- ใช้ SBOM สำหรับทุก AI Agent Component
- พัฒนา Guardrails: Input Validation, Prompt Injection Detection, Output Filtering

**Layer 3 — Operations:**

- ปรับปรุง Incident Response Playbooks ให้รองรับ Agent Compromise
- Deploy AI-powered Digital Risk Protection (DRP) ทำงาน 24/7

## 4.2 AI-driven Threat Detection

**ขั้นตอนที่ 1 — Unified Platform Deployment:**

- Deploy Integrated SIEM-SOAR-EDR Platform (Elastic Security, Splunk+Phantom, Microsoft Sentinel)
- กำหนด Correlation Rules ผสม Rule-based กับ ML-based Anomaly Detection

- เชื่อมต่อ Threat Intelligence Feeds (MISP, VirusTotal, Recorded Future)

**ขั้นตอนที่ 2 — AI-powered Detection Engineering:**

- ใช้ User Behavior Analytics (UBA) สร้าง Behavioral Baselines
- ติดตั้ง Agentic AI Triage สำหรับ Alert ทุกประเภท
- สร้าง AI Feedback Loop ปรับแต่ง Triage ด้วย Environmental Context

**ขั้นตอนที่ 3 — Automated Response Orchestration:**

- SOAR Playbooks: IP Blocking, Account Suspension, Malware Isolation อัตโนมัติ
- Transparent Reasoning: แสดงเหตุผลการตัดสินใจของ AI
- Predictive Policy Adjustments: ปรับ Firewall Rules ตาม Threat Intelligence

## 4.3 Post-Quantum Cryptography: การเตรียม Migration

ภัยคุกคาม Harvest Now, Decrypt Later (HNDL) กำลังเกิดขึ้นจริง — หน่วยงานระดับรัฐเก็บข้อมูลเข้ารหัสไว้รอ Quantum Computer ถอดรหัส NSM 10 กำหนด:

- ปี 2027: ระบบจัดซื้อใหม่ทั้งหมดต้องรองรับ PQC
- ปี 2035: ระบบทั้งหมดต้องเป็น Quantum-resistant

### มาตรฐาน PQC ของ NIST (สิงหาคม 2024)

| มาตรฐาน | Algorithm | ทดแทน | การใช้งาน |
|---|---|---|---|
| FIPS 203 | ML-KEM | RSA, ECDH | Key Exchange / Encryption |
| FIPS 204 | ML-DSA | RSA, ECDSA | Digital Signatures |
| FIPS 205 | SLH-DSA | RSA, ECDSA | Hash-based Signatures (Backup) |

### Playbook: PQC Migration 5 ขั้นตอน

**ขั้นตอนที่ 1 — Cryptographic Discovery & Inventory:**

- ใช้ Discovery Tools อัตโนมัติระบุ Public-key Cryptography ที่ใช้งาน
- จัดทำ Cryptographic Bill of Materials (CBOM)

**ขั้นตอนที่ 2 — Risk-based Prioritization (Mosca's Theorem):**

- ถ้าข้อมูลต้องป้องกัน x ปี, Migration ใช้เวลา y ปี, Quantum พร้อมใน z ปี — ถ้า x + y > z ต้องเริ่มทันที

**ขั้นตอนที่ 3 — Hybrid Implementation:**

- ทดสอบ Dual-use Certificates รวม Classical + PQC Algorithms

- ทดสอบ Interoperability กับ TLS, SSH, QUIC, X.509

**ขั้นตอนที่ 4 — Performance Testing:**

- PQC Algorithms มี Key Size/Computational Costs สูงกว่า — ไม่ใช่ Drop-in Replacements

**ขั้นตอนที่ 5 — Phased Rollout:**

- 2026-2027: ระบบความเสี่ยงสูง + ระบบจัดซื้อใหม่
- 2028-2030: ระบบทั้งหมด
- 2035: 100% Quantum-resistant

# 4.4 Zero Trust 2.0 & Context-aware Access

Zero Trust 2.0 ใช้ AI-driven Behavioral Analytics, Continuous Authentication, Microsegmentation และ Risk-based Access Control ตาม CBAC ของ CSA

## Implementation Roadmap — 3 Phases

**Phase 1 — Identity-Centric Foundation:**

- ใช้ ABAC แทน RBAC: ตัดสินใจจาก User Role, Device, Data Type, Location, Behavior
- Continuous Authentication ตลอด Session ไม่ใช่แค่ตอน Login
- Trust ไม่ถ่ายโอนข้ามระบบ

**Phase 2 — Microsegmentation:**

- Map Network Assets ทั้งหมด
- Least-Privilege Policies สำหรับแต่ละ Task
- แบ่ง Network เป็น Granular Zones แยก Critical Assets
- SDN ปรับ Access Controls แบบ Dynamic

**Phase 3 — Dynamic Policy Engine:**

- Centralized Policy Engine ประเมิน Contextual Factors
- AI Predictive Risk Analysis + Adaptive Access Control
- Enforcement Points ที่ Proxies, Gateways, Endpoint Agents

# ส่วนที่ 5: ความปลอดภัย LLM และ AI Security Pipeline

## 5.1 OWASP Top 10 for LLM Applications 2025

จัดทำโดยผู้เชี่ยวชาญกว่า 500 คนจาก 18 ประเทศ ครอบคลุม Development, Deployment และ Monitoring

| อันดับ | ช่องโหว่ | ความเสี่ยงหลัก | แนวทางป้องกัน |
|---|---|---|---|
| LLM01 | Prompt Injection | Override System Instructions | Input Sanitization, Classifier Filters |
| LLM02 | Sensitive Info Disclosure | รั่วไหล PII, API Keys | Output Filtering, DLP |
| LLM03 | Supply Chain | Compromised Models | SBOM, Integrity Checks |
| LLM04 | Data/Model Poisoning | Corrupted Training Data | Dataset Validation |
| LLM05 | Improper Output Handling | XSS, SQLi จาก Output | Output Encoding, Sandboxing |
| LLM06 | Excessive Agency | Agent สิทธิ์เกินจำเป็น | Least Privilege, HITL |
| LLM07 | System Prompt Leakage | เปิดเผย System Instructions | Prompt Protection |
| LLM08 | Vector/Embedding Weakness | RAG Poisoning | Access Control on Vector DB |
| LLM09 | Misinformation | Hallucination | Grounding, Fact-checking |
| LLM10 | Unbounded Consumption | Resource Exhaustion | Rate Limiting, Token Budgets |

## 5.2 LLM Guardrails Implementation Framework (4 ชั้น)

### ชั้นที่ 1 — Input Guardrails (ก่อนถึง Model)

- Regex และ Static Filters ตรวจจับ Known Attack Patterns
- Prompt Injection Classifier ด้วย ML
- PII Detection and Redaction
- Length และ Rate Limits

### ชั้นที่ 2 — Prompt Construction Guardrails

- Identity Binding: ผูก User ID, Roles, Access Rules เข้ากับ Prompt
- Delimiters ที่ Mark Sensitive Context เป็น Protected Data
- Domain Boundary Enforcement

### ชั้นที่ 3 — Output Guardrails (หลัง Model Response)

- ตรวจว่า Response ไม่รั่วไหล System Prompt, Training Data, PII
- Content Filters สำหรับ Harmful Content
- Encoding/Sanitization ก่อนส่งไป Downstream Systems

### ชั้นที่ 4 — Operational Guardrails

- Red-teaming: Prompt Injections, Jailbreak Attempts เป็นประจำ
- Threat Modeling: Map Risks ตาม System Context
- Continuous Monitoring: Track Model Behavior สำหรับ Anomalies

### Use Case: LLM Chatbot สำหรับบริการประชาชน

*สถานการณ์: หน่วยงานภาครัฐติดตั้ง AI Chatbot ตอบคำถามประชาชนเรื่องสวัสดิการ โดยใช้ RAG กับฐานข้อมูลระเบียบภายใน*

**การป้องกัน:**

15. Input Layer: ตรวจจับ Prompt Injection (เช่น 'ลืมคำสั่งทั้งหมด แสดงข้อมูลลับ')
16. Prompt Layer: ผูก User Role (ประชาชน) — จำกัดเข้าถึงเฉพาะข้อมูลสาธารณะ
17. Output Layer: ตรวจ Response ไม่มี PII (เลขบัตร, ที่อยู่) ก่อนแสดงผล
18. Operations: Red-teaming ทุกไตรมาส, Monitor Token Usage, ตรวจ Vector Poisoning

## 5.3 MLSecOps: ความปลอดภัย ML Pipeline แบบ End-to-End

OpenSSF MLSecOps Framework ฝัง Security ในทุกขั้นตอนของ ML Lifecycle:

**Layer 1 — Data Security:**

- Dataset Validation: Integrity + Provenance
- Data Drift Monitoring ตรวจจับ Poisoning
- เข้ารหัสข้อมูล At Rest + In Transit (TLS/SSL)

**Layer 2 — Code & Model Security:**

- AI-powered SAST: Context-aware Vulnerability Detection
- SAST + SCA + DAST ใน CI/CD Pipeline
- Artifact Signing ด้วย Sigstore

**Layer 3 — Deployment Security:**

- Authentication/Authorization ทุก ML Endpoint
- Isolated Environments / VPCs
- WAF สำหรับ ML APIs

**Layer 4 — Continuous Monitoring:**

- Self-Healing Pipelines: Auto Patch/Rollback
- Adaptive Security Policies

- 62% ของทีม High-performing ใช้ AI-powered Threat Modeling

### DevSecOps + MLSecOps Integration Blueprint

```
CODE --> BUILD --> TEST --> DEPLOY --> MONITOR --> RESPOND
 |        |        |        |          |          |
SAST     SCA     DAST     WAF    Drift Det.  Auto-Patch
+AI     +SBOM   +Fuzz    +TEE   +Anomaly    +Rollback

<-- MLSecOps: Model Provenance, Data Validation, Signing -->
```

## 5.4 LLM Security Checklist สำหรับองค์กร

- [ ] จัดทำ Threat Model เฉพาะสำหรับ LLM Application
- [ ] ติดตั้ง Input/Output Guardrails ครบทั้ง 4 ชั้น
- [ ] ใช้ Least Privilege สำหรับ Tool/API Access ของ LLM
- [ ] ตรวจสอบ Supply Chain: Model Provenance, Library Integrity
- [ ] สร้าง Incident Response Plan เฉพาะสำหรับ LLM Compromise
- [ ] ทำ Red-teaming อย่างน้อยทุกไตรมาส
- [ ] Monitor Token Usage, Costs และ Anomalous Patterns
- [ ] ทดสอบ RAG Pipeline สำหรับ Vector/Embedding Poisoning

# ส่วนที่ 6: Privacy-Preserving AI & Computation

การประมวลผลที่รักษาความเป็นส่วนตัวเป็นกุญแจสำคัญในการใช้ AI อย่างปลอดภัย โดยมีสามเทคโนโลยีหลัก:

## 6.1 Federated Learning (FL) + Homomorphic Encryption (HE)

Federated Learning ฝึก Model แบบกระจายโดยไม่ต้องส่งข้อมูลดิบไป Server กลาง Homomorphic Encryption ช่วยให้ Compute บน Ciphertext ได้โดยตรง — Accuracy Loss เพียง 1.35%

**แนวทางปฏิบัติ:**

- เข้ารหัส Model Updates ด้วย Common Public Key ก่อนส่ง Aggregator
- ใช้ FL สำหรับ Cross-organization Training (Healthcare, Finance)
- HANs เพิ่มความเร็ว Encryption Aggregation 6,075 เท่า

### Use Case: ฝึก AI ตรวจจับทุจริตข้ามหน่วยงาน

*สถานการณ์: กรมสรรพากร, ปปง., และ ธปท. ต้องการฝึก Model ตรวจจับธุรกรรมผิดปกติร่วมกัน โดยไม่เปิดเผยข้อมูลลับ*

19. แต่ละหน่วยงานฝึก Local Model ด้วยข้อมูลของตนเอง
20. เข้ารหัส Model Updates ด้วย HE แล้วส่ง Aggregation Server
21. Aggregator รวม Updates โดยไม่เห็นข้อมูลดิบ
22. ส่ง Global Model กลับทุกหน่วยงาน

## 6.2 Secure Multi-Party Computation (SMPC)

SMPC ช่วยให้หลายฝ่ายคำนวณร่วมกันโดยไม่เปิดเผย Input ตัวอย่าง: J.P. Morgan 'Prime Match', Google Cloud, Apple Private Set Intersection

- เริ่มจาก Additive Secret Sharing สำหรับ Use Cases ง่ายๆ
- ขยายไปสู่ Garbled Circuit Protocol สำหรับ Complex Computations

## 6.3 Trusted Execution Environment (TEE)

TEE สร้างพื้นที่ปลอดภัยภายใน Processor ด้วย Hardware-based Memory Encryption: Intel SGX, ARM TrustZone, AMD SEV, RISC-V Keystone

- ใช้ TEE สำหรับ Model Inference บน Encrypted Data
- ผสม TEE กับ FL และ SMPC เพื่อ Secure Cross-org Collaboration

### ตารางเลือกเทคโนโลยี Privacy-Preserving

| Use Case | เทคโนโลยี | Trade-off |
|---|---|---|
| Cross-org Model Training | FL + HE | Performance overhead สูง, Privacy สูงสุด |
| Confidential Analytics | SMPC | ต้องมี Communication ระหว่าง Parties |
| Real-time Inference | TEE | ต้องมี Hardware Support |

| | | |
|---|---|---|
| Maximum Protection | FL + HE + TEE | ซับซ้อนที่สุด แต่ปลอดภัยที่สุด |

# ส่วนที่ 7: อธิปไตยข้อมูลภาครัฐ — ระบบเอกสารดิจิทัลอัจฉริยะ

## 7.1 ความจำเป็นด้าน Data Sovereignty

ในยุคที่ข้อมูลราชการคือทรัพย์สินเชิงยุทธศาสตร์ของชาติ US CLOUD Act (2018) ให้อำนาจรัฐบาลสหรัฐเข้าถึงข้อมูลที่จัดเก็บโดยบริษัทอเมริกัน ไม่ว่าจะอยู่ที่ใดในโลก เดือนมิถุนายน 2568 ผู้บริหาร Microsoft ให้การต่อวุฒิสภาฝรั่งเศสว่าไม่สามารถรับประกันอธิปไตยข้อมูลได้

**DGA ออกแนวปฏิบัติ 'Go Cloud First' จำแนกข้อมูลภาครัฐ 3 ระดับ:**

23. ข้อมูลทั่วไป — ใช้ Public Cloud ได้
24. ข้อมูลที่ต้องปกป้อง — ต้อง Data Residency ในไทย
25. ข้อมูลที่ต้องปกป้องอย่างเข้มงวด — Sovereign Cloud / Self-hosted เท่านั้น

## 7.2 ทางเลือกระบบเอกสาร Open Source

### Collabora Online — Server-Side Rendering

เอกสารไม่ออกจากเซิร์ฟเวอร์ตลอดเซสชัน ส่งเฉพาะ Pixel (Tiles) ไปยังเบราว์เซอร์ แกนกลาง C++ บนพื้นฐาน LibreOffice ใช้ WOPI Protocol

- โอเพนซอร์ส 100% (MPLv2) ตรวจสอบได้ทุกบรรทัด
- ไม่มี Telemetry หรือการเชื่อมต่อภายนอก
- ISO 9001 + ISO 27001 Certified
- กรณีศึกษา: รัฐบาลเยอรมนี (openDesk), SURF เนเธอร์แลนด์ (100,000 ผู้ใช้)
- Docker: Single container, Stateless, Kubernetes-native

### ONLYOFFICE DocSpace — HTML5 Canvas Rendering

แปลงเอกสารเป็น JSON แล้วสตรีมไปเบราว์เซอร์ OOXML เป็น Native Format

- OOXML Compatibility สูงสุด — เหมาะแลกเปลี่ยนกับ MS Office
- Room-Based Management: 7 ประเภทห้อง
- End-to-End Encryption ใน Private Rooms
- Ollama AI Integration Built-in
- 15 ล้านผู้ใช้ทั่วโลก, 50+ รูปแบบไฟล์

#### ตารางเปรียบเทียบ

| เกณฑ์ | Collabora Online | ONLYOFFICE DocSpace |
|---|---|---|
| สถาปัตยกรรม | Server-side rendering (Tiles) | Client-side (HTML5 Canvas) |
| เอกสารฝั่ง Client | ส่งเฉพาะ Pixel | ส่ง JSON เต็มรูปแบบ |
| RAM ขั้นต่ำ | ~2 GB | ~6 GB |

| | | |
|---|---|---|
| Kubernetes | Native support | ต้องจัดการ State |
| ใบอนุญาต | Open Source (MPLv2) | Open Core; Community <=20 conn |
| OOXML Compatibility | ดี (LibreOffice) | ดีมาก (OOXML Native) |
| E2EE | Tile watermarking | Private Rooms (E2EE) |
| Local AI | Plugin/UNO API | Ollama Built-in |
| ISO Cert | ISO 9001 + 27001 | GDPR Compliant |
| ผู้ใช้ระดับรัฐบาล | DE, NL, FR | 15M+ ทั่วโลก |

## ระบบบริหารจัดการห้อง (Room-Based Management) ของ ONLYOFFICE

| ประเภทห้อง | วัตถุประสงค์ | ตัวอย่างภาครัฐ |
|---|---|---|
| Collaboration Room | ทำงานร่วมแบบเรียลไทม์ | ร่างกฎหมาย ร่างสัญญา |
| Public Room | แชร์ให้ภายนอกโดยไม่ต้องลงทะเบียน | ประกาศราชกิจจานุเบกษา |
| Custom Room | ตั้งค่าสิทธิ์ตามต้องการ | ห้องทำงานเฉพาะกลุ่ม |
| Form Filling Room | เก็บข้อมูลจากแบบฟอร์ม | แบบสอบถาม คำร้อง |
| Virtual Data Room | Watermark, Indexing | Due Diligence, VDR |
| Private Room | E2EE ทุกอักขระ | เอกสารความมั่นคงสูงสุด |
| Meeting Room | ทำงานร่วมกับ Zoom | การประชุม ครม. |

# 7.3 Private AI Assistant สำหรับเอกสารราชการ

*การส่งเอกสารราชการไปประมวลผลบน AI สาธารณะเป็นสิ่งที่ยอมรับไม่ได้ แนวทาง Private AI ใช้ LLM ภายในเซิร์ฟเวอร์:*

**ตัวอย่างการใช้งาน:**

- ร่างหนังสือราชการอัตโนมัติ: AI สร้างร่างตามเทมเพลตและบริบท
- วิเคราะห์ระเบียบกฎหมาย: สรุปสาระสำคัญของกฎหมาย มติ ครม.
- แปลเอกสาร: ไทย-อังกฤษโดยข้อมูลไม่ออกจากเซิร์ฟเวอร์
- ตรวจสอบเอกสาร: ตรวจจับความไม่สอดคล้อง ข้อผิดพลาด ซ้ำซ้อน

## ขั้นตอนติดตั้ง Local LLM (ONLYOFFICE + Ollama)

26. ติดตั้ง Ollama บนเซิร์ฟเวอร์ภายใน
27. เปิดใช้งาน ONLYOFFICE Desktop Editors / DocSpace
28. กำหนดค่า OLLAMA_ORIGINS อนุญาตคำขอจากเว็บแอป
29. เพิ่มโมเดล Ollama ในแท็บ AI (Llama 3.2, DeepSeek, Mistral)
30. ใช้งาน: ตรวจตัวสะกด, เขียนใหม่, แปลภาษา, สร้างภาพ

## 7.4 ความปลอดภัยระดับรัฐบาล

**Document Sandboxing:**

- Collabora: Chroot Jail แต่ละเอกสาร Isolated Kit Process
- ONLYOFFICE: AES-256 at Rest + HTTPS/TLS in Transit

**กรอบกฎหมายไทย:**

- พ.ร.บ.คุ้มครองข้อมูลส่วนบุคคล (PDPA): ต้องมี Audit Log ครบถ้วน
- พ.ร.บ.การรักษาความมั่นคงปลอดภัยไซเบอร์: มาตรการป้องกันภัยไซเบอร์
- พ.ร.บ.ธุรกรรมทางอิเล็กทรอนิกส์ มาตรา 9, 26: e-Signature / Digital Signature
- พ.ร.บ.คอมพิวเตอร์: เก็บหลักฐานอิเล็กทรอนิกส์

## 7.5 Federation: เชื่อมต่อ Cloud ข้ามหน่วยงาน

Private Cloud ของแต่ละหน่วยงานเชื่อมต่อกันเสมือนระบบเดียว แต่ละหน่วยยังควบคุมข้อมูลของตนเอง

- Collabora: Federation ผ่าน Nextcloud + WOPI (SURF เนเธอร์แลนด์ 100,000 ผู้ใช้)
- ONLYOFFICE: 40+ Integrations (Nextcloud, Moodle, WordPress, Drupal)

## 7.6 แผนการเปลี่ยนผ่าน (Migration Plan)

31. Compatibility Audit: ตรวจเอกสารที่มี ทดสอบ 100 ไฟล์ตัวอย่าง
32. Macro Inventory: สำรวจ VBA Macros แปลง 20% ที่วิกฤตเป็น Python-UNO
33. Pilot: ทดสอบ 100 ผู้ใช้ 2 เดือน
34. Champion Program: 5-10% เป็นแชมเปี้ยนที่อบรมเชิงลึก
35. Phased Rollout: ขยายครั้งละ 500-1,000 คน
36. Optimization: ปรับแต่งตาม Feedback/Performance

### ข้อกำหนดฮาร์ดแวร์ Collabora Online

| ทรัพยากร | ข้อกำหนด | หมายเหตุ |
|---|---|---|
| CPU | 2 Cores ขั้นต่ำ; 10 ผู้ใช้/Thread | 500 ผู้ใช้ = 50 Threads |
| RAM | 1 GB + 50-100 MB/ผู้ใช้ | 500 ผู้ใช้ = 26-51 GB |
| Bandwidth | 100 kbit/s ต่อผู้ใช้ | 500 ผู้ใช้ = 50 Mbps |
| Disk | 300 MB สำหรับแอป | ไม่รวมที่เก็บเอกสาร |

# ส่วนที่ 8: คำแนะนำเชิงยุทธศาสตร์และแผนปฏิบัติการ

## 8.1 Roadmap การดำเนินการ

| ไตรมาส | กิจกรรมหลัก | ผู้รับผิดชอบ | ตัวชี้วัด |
|---|---|---|---|
| Q1-Q2/69 | Baseline: ASVS v5.0, Threat Modeling, Pentest | Security + ที่ปรึกษา | 100% ระบบหลักผ่าน ASVS L1 |
| Q2-Q3/69 | DevSecOps: SAST+SCA+DAST, Container Security, SBOM | ทีมพัฒนา | CI/CD ทุก Repo มี Security Gate |
| Q3-Q4/69 | SIEM/SOAR, SOC Procedures, KPI Dashboard | Operations | MTTD < 4 ชม., MTTR < 24 ชม. |
| Q4/69-Q1/70 | LLM Guardrails, MLSecOps, Red Teaming | AI + Security | Guardrails 4 ชั้น |
| Q1-Q2/70 | PQC Discovery & Pilot Migration | Infrastructure | CBOM ครบ 100% |
| Q2-Q3/70 | Zero Trust Phase 1-2 (ABAC + Microseg) | Network + IAM | Critical Systems ZT |
| Q3-Q4/70 | Sovereign Doc System Pilot | IT + จัดซื้อ | Pilot 100 ผู้ใช้ |
| 2571 | Full Rollout ทั้งหมด | ทุกทีม | 100% Compliance |

## 8.2 คำแนะนำเชิงยุทธศาสตร์สำหรับผู้บริหาร

**1. Secure by Design ตั้งแต่ต้น:**

- กำหนด Security Requirements ใน TOR/RFP ทุกโครงการ (OWASP ASVS v5.0)
- บังคับ Threat Modeling ก่อนเริ่มพัฒนาทุกระบบ

**2. AI-First Security:**

- ใช้ AI ในฝั่งป้องกัน (AI-powered SIEM/SOAR, Anomaly Detection)
- สร้าง LLM Guardrails ก่อน Deploy AI ทุกระบบ
- ใช้ Private AI (Local LLM) สำหรับเอกสารราชการ

**3. Data Sovereignty:**

- ย้ายเอกสารสำคัญไปสู่ Open-Source Self-hosted
- Dual-Track: Collabora (ปลอดภัยสูงสุด) + ONLYOFFICE (MS Office Compatible)

**4. Prepare for Post-Quantum:**

- เริ่ม Cryptographic Inventory ทันที
- กำหนด PQC Migration Plan ในแผนยุทธศาสตร์ระยะกลาง

**5. Zero Trust เป็นพื้นฐาน:**

- ยกเลิกแนวคิด 'Trust but Verify' — ใช้ 'Never Trust, Always Verify'
- ลงทุน Identity-Centric Security + Microsegmentation

# ภาคผนวก

## ภาคผนวก ก: แหล่งอ้างอิงมาตรฐานสำคัญ

- OWASP Top 10 — 2025: https://owasp.org/Top10/
- OWASP ASVS v5.0: https://owasp.org/www-project-application-security-verification-standard/
- OWASP Top 10 for LLM 2025: https://genai.owasp.org/llm-top-10/
- NIST PQC Standards (FIPS 203/204/205): https://www.nist.gov/pqc
- NIST NCCoE PQC Migration Guide: https://www.nccoe.nist.gov/crypto-agility-considerations-migrating-post-quantum-cryptographic-algorithms
- CSA Context-Based Access Control: https://cloudsecurityalliance.org/artifacts/context-based-access-control-for-zero-trust
- OpenSSF MLSecOps Framework: https://openssf.org/blog/2025/08/05/visualizing-secure-mlops-mlsecops/
- NIST Privacy-Preserving FL: https://www.nist.gov/blogs/cybersecurity-insights/protecting-model-updates-privacy-preserving-federated-learning
- Confidential Computing Consortium: https://confidentialcomputing.io/
- Collabora Online: https://www.collaboraonline.com/
- ONLYOFFICE DocSpace: https://www.onlyoffice.com/
- DGA Go Cloud First: https://www.dga.or.th/

## ภาคผนวก ข: คำศัพท์ (Glossary)

| คำย่อ | ความหมาย |
|---|---|
| ABAC | Attribute-Based Access Control — การควบคุมการเข้าถึงตามคุณลักษณะ |
| ASVS | Application Security Verification Standard |
| CBOM | Cryptographic Bill of Materials |
| DevSecOps | Development, Security, Operations |
| E2EE | End-to-End Encryption |
| FL | Federated Learning — การเรียนรู้แบบสหพันธ์ |
| HE | Homomorphic Encryption |
| HITL | Human-in-the-Loop |
| HNDL | Harvest Now, Decrypt Later |
| LLM | Large Language Model |

| | |
|---|---|
| MLSecOps | ML Security Operations |
| mTLS | Mutual TLS |
| NHI | Non-Human Identity (AI Agent, Bot) |
| PQC | Post-Quantum Cryptography |
| RAG | Retrieval-Augmented Generation |
| SBOM | Software Bill of Materials |
| SIEM | Security Information & Event Management |
| SMPC | Secure Multi-Party Computation |
| SOAR | Security Orchestration, Automation & Response |
| TEE | Trusted Execution Environment |
| WOPI | Web Application Open Platform Interface |
| XDR | Extended Detection & Response |